3 ubuntu搭建dvwa

1、安装dvwa

下载dvwa，解压到/var/www/dvwa目录下

代码块

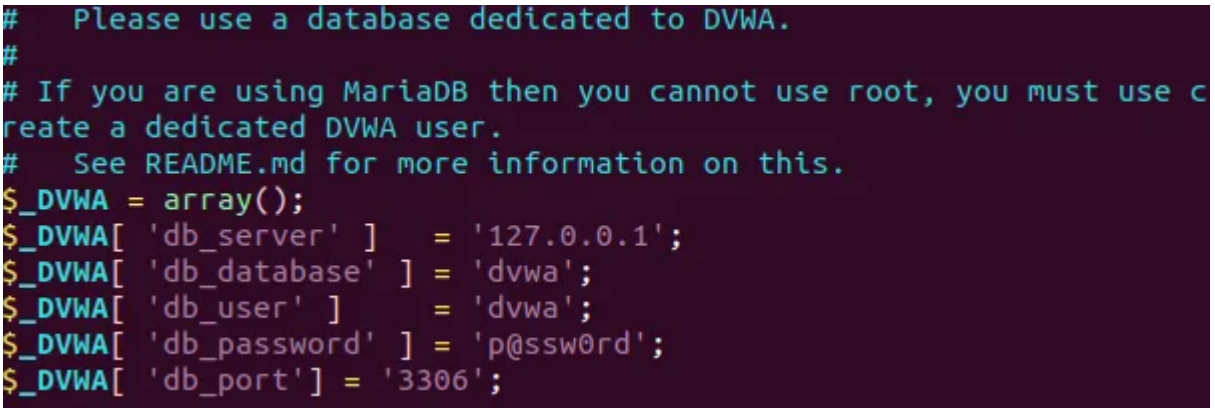
```
mkdir /var
mkdir /var/www
cd /var/www
wget https://github.com/ethicalhack3r/DVWA/archive/master.zip
unzip master.zip
mv DVWA-master dvwa
```

2、转到dvwa目录的config,修改配置文件

代码块

```
cd dvwa/config
mv config.inc.php.dist config.inc.php
```

3、编辑config.inc.php如下：



```
#   Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use c
reate a dedicated DVWA user.
#   See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ]   = '127.0.0.1';
$_DVWA[ 'db_database' ] = 'dvwa';
$_DVWA[ 'db_user' ]     = 'dvwa';
$_DVWA[ 'db_password' ] = 'p@ssw0rd';
$_DVWA[ 'db_port'] = '3306';
```

4、安装php、数据库，并启动服务

sudo apt install php php-mysql php-gd mariadb-server

systemctl start mariadb #启动 mariadb 服务。
systemctl enable mariadb #设置 mariadb 服务开机自启。

5、关闭防火墙

1. 查看防火墙状态

`sudo ufw status`

2. 禁用防火墙（ufw）

`sudo ufw disable`

3. 停止防火墙服务

`sudo systemctl stop ufw`

6、创建dvwa的数据库

代码块

```
sudo mysql

-- 创建数据库 dvwa
CREATE DATABASE dvwa;

-- 创建用户 dvwa，并设置密码为 password
CREATE USER 'dvwa'@'localhost' IDENTIFIED BY 'p@ssw0rd';

-- 赋予用户 dvwa 对数据库 dvwa 的所有权限
GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwa'@'localhost';

-- 刷新权限以使更改生效
FLUSH PRIVILEGES;

exit
```

7、修改nginx.conf配置，增加server如下：

/usr/local/nginx/conf/nginx.conf

```
代码块   server {
2            listen       8085;
3
4            location / {
5                root /var/www/dvwa;
6                index  index.html index.php;
7            }
8
9            location ~ \.php$ {
10               root /var/www/dvwa;
11               fastcgi_pass   127.0.0.1:9000;
12               fastcgi_index  index.php;
13               fastcgi_param  SCRIPT_FILENAME  $document_root$fastcgi_script_name;
14               include        fastcgi_params;
15           }
16
17       }
```

重启nginx

```
代码块
1   cd /usr/local/nginx/sbin
2   ./nginx -s reload
```

8、 确认9000端口启用

```
[root@localhost sbin]# netstat -tnlp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:42021         0.0.0.0:*               LISTEN      7944/code-019f4d141
tcp        0      0 127.0.0.1:9000          0.0.0.0:*               LISTEN      954/php-fpm: master
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      1185/mysqld
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      1014/nginx: master
tcp        0      0 127.0.0.1:37650         0.0.0.0:*               LISTEN      1946/node
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      950/sshd
tcp6       0      0 :::22                   :::*                    LISTEN      950/sshd
```

（如果服务器未启动 9000 端口，需要先安装 **PHP 及 PHP-FPM**，并在 PHP-FPM 的配置文件（如 `www.conf`）中启用并配置监听 **9000 端口**，然后启动或重启 PHP-FPM 服务，使其正常对外提供 FastCGI 服务。）

8.1 安装php、php-fpm

#apt install php

#apt install php-fpm

#systemctl status php8.3-fpm

8.2 修改www.conf文件中的listen配置

cd到/etc/php/8.3/fpm/pool.d目录，发现有一个www.conf文件

打开该文件找到listen配置，修改如下：

```
; Start a new pool named 'www'.
[www]

; The address on which to accept FastCGI requests.
; Valid syntaxes are:
;   'ip.add.re.ss:port'    - to listen on a TCP socket to a specific address on
;                            a specific port;
;   'port'                 - to listen on a TCP socket to all addresses on a
;                            specific port;
;   '/path/to/unix/socket' - to listen on a unix socket.
; Note: This value is mandatory.
listen = 127.0.0.1:9000

; Set listen(2) backlog. A value of '-1' means unlimited.
; Default Value: -1
;listen.backlog = -1

; List of ipv4 addresses of FastCGI clients which are allowed to connect.
```

8.3 重启php服务

sudo systemctl restart php8.3-fpm

9、访问一下页面，创建dvwa的数据库

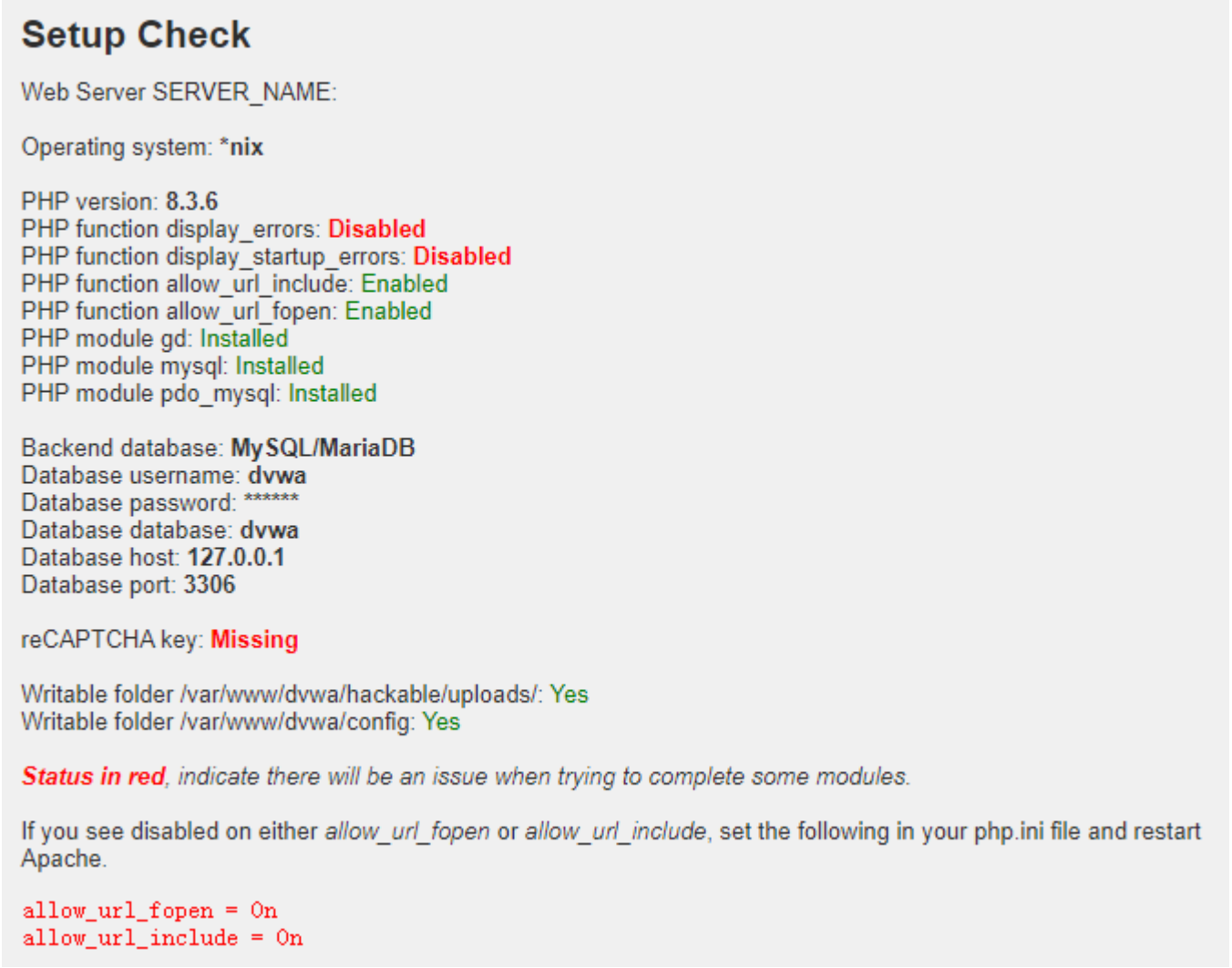
http://192.168.254.129:8085/setup.php

(上述ip为需修改自己的ip)



10、设置php.ini

如果PHP相关配置显示Disabled，需要修改php.ini配置，并重启服务



vi /var/www/dvwa/php.ini （修改该php.ini不一定生效，可以修改下面的php.ini）

vi /etc/php/8.3/fpm/php.ini

代码块

```
1   allow_url_fopen = on
2   allow_url_include = on
3   display_startup_errors = On
4   display_errors = On
```

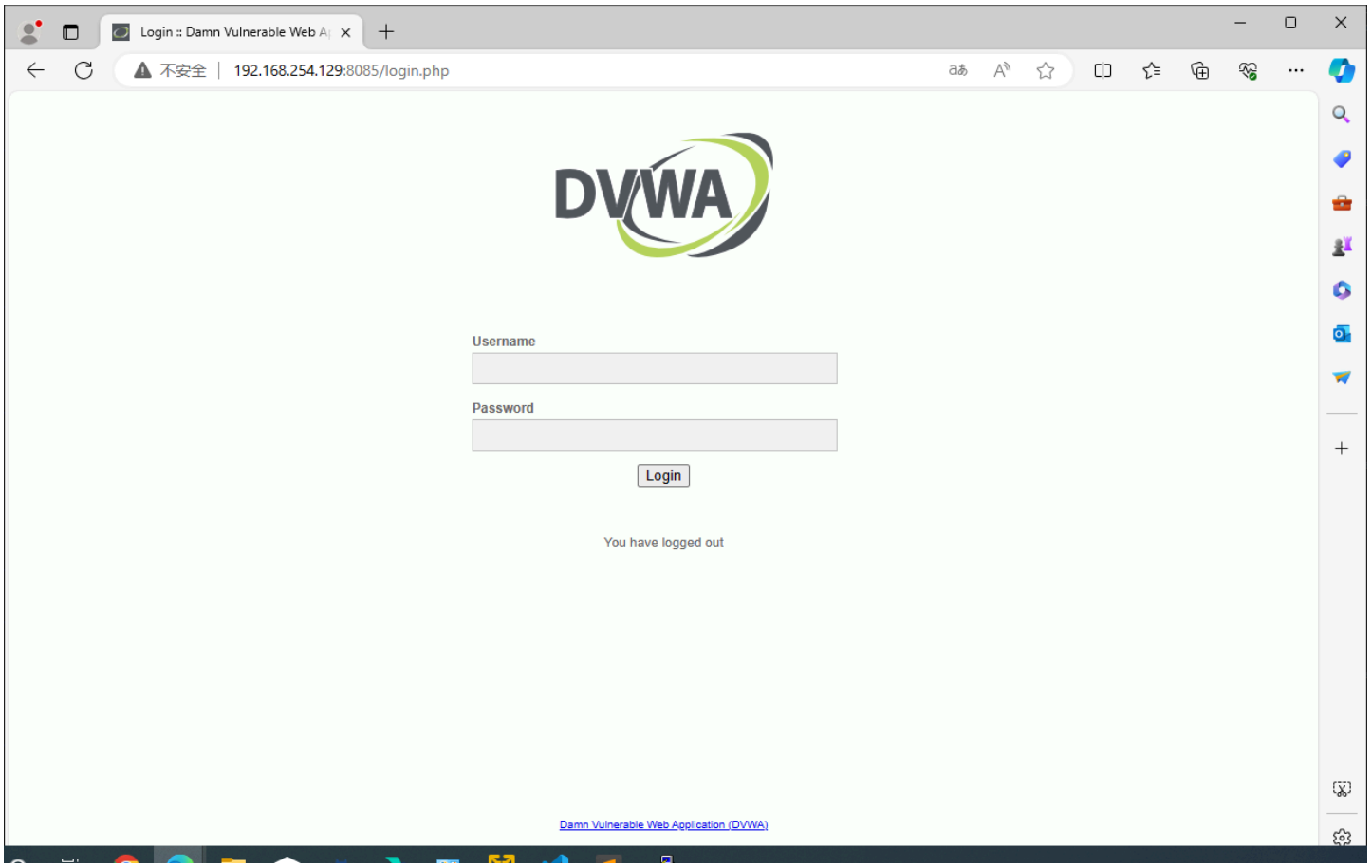
修改/etc/php/8.3/fpm/php.ini后，需要重启php服务

sudo service php8.3-fpm restart

11、再次访问dvwa

地址如下，需要将ip修改为自己的ip

http://192.168.254.129:8085/index.php

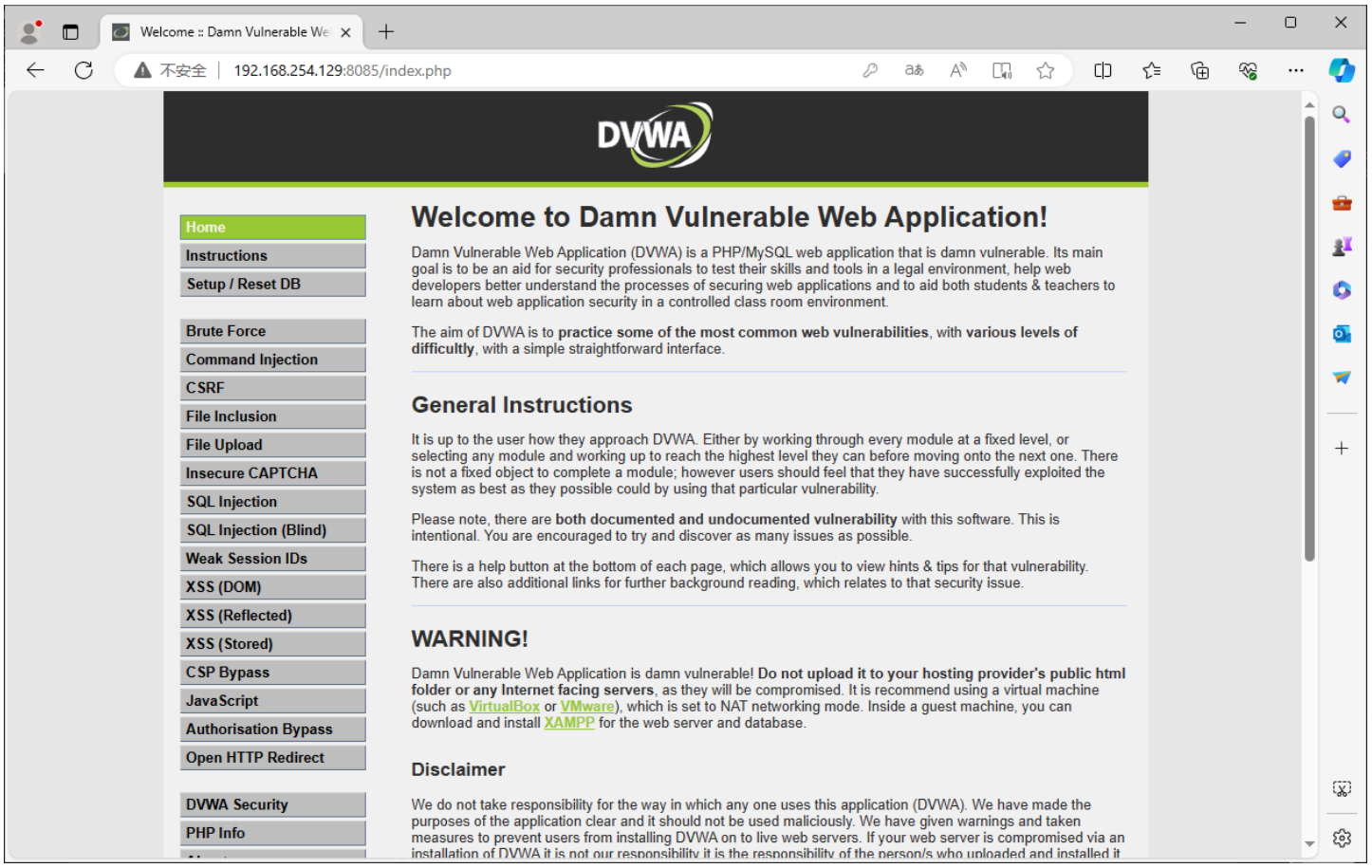


12、输入默认密码

admin

Password

进入dvwa主页面


Welcome :: Damn Vulnerable We
不安全 | 192.168.254.129:8085/index.php
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
Authorisation Bypass
Open HTTP Redirect
DVWA Security
PHP Info
Welcome to Damn Vulnerable Web Application!
Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.
The aim of DVWA is to practice some of the most common web vulnerabilities, with various levels of difficultly, with a simple straightforward interface.
General Instructions
It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.
Please note, there are both documented and undocumented vulnerability with this software. This is intentional. You are encouraged to try and discover as many issues as possible.
There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.
WARNING!
Damn Vulnerable Web Application is damn vulnerable! Do not upload it to your hosting provider's public html folder or any Internet facing servers, as they will be compromised. It is recommend using a virtual machine (such as VirtualBox or VMware), which is set to NAT networking mode. Inside a guest machine, you can download and install XAMPP for the web server and database.
Disclaimer
We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an